

FUTURE_CS_03 – API Security Risk Analysis Report

1. Executive Summary

This report presents an API security assessment performed as part of the Future Interns Cyber Security Internship – Task 3.

The assessment was conducted against OWASP crAPI, an intentionally vulnerable API security training environment. The assessment focused on authentication, authorization behavior, rate limiting, input validation, and potential data exposure.

The testing identified the following observations:

- Authentication was enforced for the tested dashboard endpoint.
- An authenticated user could retrieve their own dashboard information.
- No HTTP 429 response was observed during a small controlled rate-limit test.
- Malformed input containing an HTML/JavaScript payload was rejected with HTTP 400.
- A tested `/identity/api/v2/user/1` endpoint returned HTTP 404, so no authorization vulnerability was confirmed through that test.

The findings are presented conservatively and are based only on the evidence collected during the assessment.

2. Assessment Scope

Target

Application: OWASP crAPI

Target URL: `http://crapi.apisec.ai`

Assessment Type: API Security Risk Analysis

Testing Environment: Kali Linux

Primary Tool: cURL

The target identifies itself as an intentionally vulnerable application designed for OWASP API security training and education.

3. Assessment Objectives

The assessment focused on:

1. Authentication controls
2. Authorization behavior

3. API data exposure
 4. Rate limiting
 5. Input validation
 6. Security-related HTTP responses
 7. Business impact and remediation recommendations
-

4. Methodology

The following controlled tests were performed:

Test	Purpose	Result
Unauthenticated dashboard request	Check authentication enforcement	HTTP 401
Authenticated dashboard request	Verify authenticated access	HTTP 200
User ID authorization test	Check for potential unauthorized object access	HTTP 404
Rate-limit test	Check whether repeated requests trigger throttling	No HTTP 429 observed
Input-validation test	Test handling of malformed/script-like input	HTTP 400

All testing was limited to the designated training target.

5. Detailed Findings

F-01 – Rate Limiting Not Observed During Controlled Test

Risk Area: API Rate Limiting

Severity: Medium

Confidence: Medium

Description

A controlled test was performed against the authenticated dashboard endpoint using repeated requests.

Ten requests were sent at approximately one request per second using a valid authentication token.

No HTTP 429 Too Many Requests response was observed during this limited test.

Evidence

Evidence file:

evidence/05_rate_limit_test.txt

The captured responses returned HTTP 200.

Security Impact

If an API does not sufficiently restrict repeated requests, an attacker may be able to generate excessive traffic or repeatedly access an endpoint.

Depending on the endpoint and available resources, insufficient rate limiting can contribute to:

- Excessive API consumption
- Automated abuse
- Resource exhaustion
- Increased attack traffic
- Brute-force or enumeration attempts against sensitive endpoints

Limitation

This was a small controlled test of ten requests. The result does **not** prove that the API has no rate-limiting mechanism under larger traffic volumes or other conditions.

Recommendation

Implement and enforce rate limiting appropriate to the endpoint and business risk.

Recommended controls include:

- Per-user rate limits
 - Per-IP rate limits
 - Endpoint-specific thresholds
 - Temporary throttling after excessive requests
 - HTTP 429 Too Many Requests responses when limits are exceeded
 - Monitoring and alerting for abnormal request patterns
-

F-02 – Authenticated Dashboard Data Exposure

Risk Area: API Data Exposure

Severity: Low / Informational

Confidence: High

Description

After successful authentication, the dashboard endpoint returned several attributes belonging to the authenticated test account.

The response included fields such as:

- User ID
- Name
- Email address
- Phone number
- Credit information
- Account role

Evidence

Evidence file:

evidence/03_authenticated_dashboard.txt

The authenticated request returned HTTP 200.

Security Impact

Authenticated APIs should expose only the information required for the intended functionality.

If unnecessary account attributes are exposed to clients, excessive data may increase the impact of an account compromise or accidental disclosure.

Important Assessment Limitation

The test only demonstrated access to the **authenticated test user's own data**.

A cross-user data-access vulnerability was **not confirmed** during this assessment.

Recommendation

Apply data-minimization principles to API responses.

Recommended controls include:

- Return only fields required by the client.
- Avoid exposing unnecessary sensitive attributes.
- Apply object-level authorization to every resource.

- Validate that users can access only records they are authorized to access.
 - Review API response schemas for excessive data exposure.
-

6. Authentication Control Observed

F-03 – Authentication Enforcement

Classification: Security Control Observed

Status: Working as Tested

An unauthenticated request was sent to:

`/identity/api/v2/user/dashboard`

The API returned:

“text HTTP/1.1 401